

CANLIFAL_BACKEND_TEST_PLAN.md — Backend Test Planı (§87)

Sürüm: 1.0 · **Tarih:** 2026-08-27 · **Platform:** canlifal.com

Kapsam envanteri: 780 handler · 502 path · 172 kategori · 215 model · 109 hata kodu · 20 SSE ucu · 18 rate-limit kovası · 11 idempotent uç · 12 imleçli uç · 50 transaction çağırısı.

Bu doküman, §87'nin istediği on test sınıfını ayrı ayrı tanımlar. Her sınıf için **amaç**, **kapsam**, **araç**, **örnek senaryolar**, **geçme ölçütü** ve **çalıştırma sıklığı** verilir.

Bu bir plan dokümanıdır; test kodu henüz yazılmamıştır. Aşağıdaki tabloların “Durum” sütunu mevcut gerçekliği gösterir.

0. Ortam ve Ön Koşullar

Bileşen	Değer
API taban adresi	https://canlifal.com/api (üretim), http://localhost:3000/api (geliştirme)
Kimlik (mobil)	POST /api/auth/mobile-login → accessToken (7 gün), refreshToken (30 gün)
Kimlik (web)	Oturum çerezi
Test hesabı	Geliştirme ortamında tohumlanan hesap; kimlik bilgileri ortam değişkenlerinden okunur
Veritabanı	Tek PostgreSQL — geliştirme ve üretim aynı örneği paylaşır
Kısıtlar	25 eşzamanlı bağlantı · 5sn ifade zaman aşımı · 30sn boşta-transaction zaman aşımı

Altın kural: Paylaşımlı veritabanı nedeniyle hiçbir test toplu veri silme işlemi yapmaz. Tüm testler kendi ürettiği kayıtlar üzerinde çalışır ve test_ önekli kimliklerle izlenir.

1. Unit Test

Amaç: Yan etkisiz saf fonksiyonların doğruluğu.

Kapsam: lib/ altındaki yardımcı modüller — veritabanı veya ağ erişimi olmayanlar.

Hedef modül	Test edilecek davranış	Durum
lib/pagination.ts	isCursorMode mod seçimi, fetchCursorPage limit+1 kırpması, boş sayfa	Yazılmadı
lib/api-response.ts	109 hata kodunun benzersizliği, zarf şekli, request_id üretimi	Yazılmadı
lib/notify.ts	buildNotificationDedupeKey determinizmi, resolveNotificationDeepLink türetme kuralları, pencere seçimi	Yazılmadı
lib/permissions.ts	Rol → izin çözümü, kalıtım, bilinmeyen izin davranışı	Yazılmadı

Hedef modül	Test edilecek davranış	Durum
lib/media-url.ts	Görelî yolun tam CDN adresine çevrilmesi, boş/null giriş	Yazılmadı
lib/rate-limit-guard.ts	Kova penceresi hesabı, pencere istisnaları, uzaktan yapılandırma birleştirme	Yazılmadı

Araç: Vitest veya Jest (ts-node ile); veritabanı taklidi yok — bu modüller saf tutulmalı.

Geçme ölçütü: Hedef modüllerde satır kapsamı $\geq 80\%$; her hata kodu en az bir doğrulamada geçmeli.

Sıklık: Her commit.

2. Integration Test

Amaç: Handler + veritabanı + yardımcı katman birlikte doğru çalışıyor mu.

Kapsam: Gerçek veritabanına yazan, tek bir iş akışını uçtan uca kapsayan senaryolar.

Senaryo	Adımlar	Beklenen
Falci seansı yaşam döngüsü	Talep oluştur → falci kabul et → mesajlaş → bitir	LiveSession.status geçişleri doğru; kredi rezerve → tahsil
Seans reddi	Talep oluştur → falci reddet	Kredi tam iade; session_cancelled olayı yayınlanır
Oda koltuk akışı	Odaya gir → koltuk al → konuşma izni iste → çık	ChatPresence tek kayıt; koltuk serbest bırakılır
Hediye → ajans payı	Ajanslı yayıncıya hediye gönder	LedgerEntry çok bacaklı; AgencyEarning aynı transaction'da
Bildirim tekilleştirme	Aynı metinle 3 mesaj gönder	3 mesaj, 1 bildirim, deepLink dolu
Para çekme onayı	Talep → admin onay	Bakiye düşer, LedgerEntry yazılır, AuditLog kaydı oluşur

Araç: Node test koşucusu + fetch; her senaryo kendi kullanıcı çiftini oluşturur.

Geçme ölçütü: Tüm senaryolar yeşil; senaryo sonunda sahipsiz kayıt bırakılmaz.

Sıklık: Her birleştirme (merge) öncesi.

3. API Test (sözleşme testi)

Amaç: 502 yolun her birinin sözleşmeye (durum kodu, zarf, alan adları) uyması.

Kapsam matrisi:

Boyut	Doğrulanacak
Kimlik	Token yok → 401 · Yanlış rol → 403 · Geçerli → 200

Boyut	Doğrulanacak
Doğrulama	Eksik zorunlu alan → 400 + ErrorCodes sabiti
Bulunamadı	Var olmayan kimlik → 404
Yöntem	Desteklenmeyen HTTP yöntemi → 405
Şekil	Zarflı uçlarda {success, data, meta?, request_id}; eski uçlarda mevcut şekil birebir korunmalı
Sayfalama	page/limit varsayılan; ?cursor= verildiğinde meta.cursor + meta.hasMore
CDN	Medya alanları tam nitelikli adres döner

Kritik regresyon kuralı: Eski (zarfsız) uçlar için sözleşme testi **mevcut yanıtın anlık görüntüsüdür**. Şekil değişirse test kırılır — bu kasıtlıdır; geriye dönük uyumluluk zorunludur.

Araç: backend-docs/openapi.json + backend-docs/postman_collection.json üzerinden sözleşme koşucusu (Schemathesis / Dredd / Newman).

Geçme ölçütü: 502 yolun $\geq$ %95'i otomatik kapsanır; kapsanmayanlar gerekçeli listelenir.

Sıklık: Gecelik.

4. Realtime Test (SSE)

Amaç: 20 SSE ucunun bağlantı, yeniden bağlanma ve olay sırası davranışı.

Senaryo	Beklenen
Bağlantı kurulumu	200 + text/event-stream; ilk anlık görüntü olayı gelir
Kalp atışı	15 saniyede bir : heartbeat yorum satırı
Yoklama periyodu	Yeni olay en geç 2 saniyede istemciye ulaşır
Last-Event-ID ile yeniden bağlanma	Kopan noktadan sonraki olaylar tekrar oynatılır (2dk / 200 olay tamponu)
?lastEventId= sorgu değişkeni	Başlık ile aynı davranış
Varlık (presence) anlık görüntüsü	10 saniyede bir tam liste
Yetki	Odaya erişimi olmayan kullanıcı → 403, akış açılmaz
Yayın sonu	streamEnded olayı sonrası akış kapanır
Kopya olay	Aynı id iki kez gelirse istemci tekilleştirebilmeli (olay kimlikleri epoch-ms)

Kapsanacak kanallar: sohbet odası, video yayın, falcı seansı, falcı talep, bildirim, PK maç, fal yanıt akışı — ayrıntılı olay listesi CANLIFAL_REALTIME_EVENTS.md.

Araç: curl -N tabanlı betik + zaman damgası ölçümü.

Geçme ölçütü: Her kanal için bağlantı, kalp atışı ve yeniden oynatma senaryosu geçer; olay kaybı sıfır.

Sıklık: Gecelik + gerçek zamanlı kod değişikliğinde.

5. Concurrency Test

Amaç: Yarış koşullarının (race condition) tekrar açılmadığını doğrulamak.

Senaryo	Paralel istek	Beklenen
Aynı koltuğa iki kullanıcı	2 × koltuk al	Biri başarılı, diğeri “koltuk dolu”; çift kayıt yok
Aynı kullanıcı çift hediye	10 × hediye gönder	Bakiye tam olarak 10 hediye kadar düşer, negatife inmez
Günlük görev iki kez talep	5 × claim	1 ödül; kalanlar “zaten alındı”
Günlük giriş ödülü	5 × claim	1 ödül; P2002 yakalanır, 500 dönmez
PK skor eşzamanlı katkı	20 × hediye	Toplam skor kayıpsız
Takip/bırakma dalgası	10 × takip + 10 × bırak	Son durum tutarlı, Follow unique ihlali sızmaz
Aynı x-idempotency-key	5 × aynı istek	1 kez işlenir, 4 yanıt tekrar (replay)

Araç: Promise.all ile eşzamanlı fetch; veritabanı bağlantı sınırı (25) aşılmayacak şekilde parti büyüklüğü ≤ 10 .

Geçme ölçütü: Hiçbir senaryoda çift finansal etki, negatif bakiye veya 500 hatası yok.

Sıklık: Haftalık + transaction’a dokunan her değişiklikte.

6. Financial Test

Amaç: Para hareketlerinin mutabakatı. En yüksek öncelikli test sınıfı.

Kontrol	Yöntem
Çift kayıt dengesi	Her LedgerEntry grubunda bacakların toplamı sıfır
Bakiye ↔ defter	User.jetonBalance = ilgili defter bacaklarının toplamı
Komisyon oranları	Hediye tutarı × yapılandırılmış yüzde = alıcı/oda/platform payları (yuvarlama dahil)
İade	İptal/ret edilen seansta rezerve kredi tam iade
Ajans payı	AgencyEarning toplamı = üye kazançlarının komisyon oranı
Para çekme	Talep tutarı > bakiye → reddedilir; onayda bakiye tam düşer
Değiştirilemezlik	LedgerEntry üzerinde güncelleme/silme denemesi başarısız olmalı
Yuvarlama	Kuruş kaybı yok; toplam dağıtım = kaynak tutar

Örnek mutabakat kontrolü: Belirli bir zaman aralığında gönderilen hediyelerin toplam jeton değeri, aynı aralıktaki defter bacaklarının mutlak toplamının yarısına eşit olmalıdır.

Geçme ölçütü: Sapma toleransı 0. Tek kuruşluk fark bile başarısızlıktır.

Sıklık: Gecelik mutabakat işi + her finansal kod değişikliğinde.

7. Security Test

Amaç: Yetkisiz erişim, veri sızıntısı ve kötüye kullanım yollarının kapalı olması.

Kategori	Senaryo	Beklenen
Kimlik doğrulama Süresi dolmuş token	Token'sız korumalı uç 7 günü aşmış access token	401 401 + yenileme akışına yönlendirme
Yetkilendirme IDOR	Normal kullanıcı → admin ucu Başkasının sessionId / ticketId / orderId ile istek	403 403 veya 404, veri sızmaz
Kimlik kaynağı	Gövdede sahte userId gönderimi	Yok sayılır; oturumdaki kimlik kullanılır
Rate limit	Kova sınırını aşan istek	429 + Retry-After + X-RateLimit-* başlıkları
Enjeksiyon Yükleme Gizli veri	Sorgu enjeksiyonu yükleri İzinsiz MIME, aşırı boyut Yanıtlarda parola özeti, token, anahtar	ORM parametrelenmiş; etkisiz Reddedilir Hiçbir uçta dönmez
Denetim izi	Admin işlemi sonrası AuditLog	Kayıt oluşur, aktör ve hedef dolu
Anti-fraud	Şüpheli desen (hızlı çok hesap, anormal hediye)	RiskEvent üretilir

Rate-limit kovaları (18): api_default, auth, gift_send, lucky_gift, chat_message, comment, content_create, withdrawal, payment, stream_create, room_create, pk_create, agency_action, tip, membership, report, upload, rtc_telemetry. Bunlardan 16'sı handler'larda etkin kullanımdadır.

Geçme ölçütü: Kritik bulgular (IDOR, yetki atlatma, gizli veri sızıntısı) sıfır.

Sıklık: Sürüm öncesi + aylık.

8. WebRTC Signaling Test

Amaç: Sinyalleşme kanallarının doğru eşleştirme ve temizleme davranışı.

Senaryo	Beklenen
Teklif/yanıt (offer/answer)	Gönderen → alıcı yönlendirmesi doğru; üçüncü taraf göremez
ICE aday akışı Sayfa yenileme	Sırayla teslim; işlenen sinyal tekrar dönmez DELETE /api/room/signal eski sinyalleri temizler; yeni müzakere temiz başlar
Yetkisiz sinyal Yayın sinyali Telemetri	Seansa ait olmayan kullanıcı → 403 /api/video-streams/signal üzerinde aynı kurallar RtcTelemetry kaydı oluşur; kalite skoru eşiklerden hesaplanır
Kopma	Bir taraf düşerse diğer tarafa durum yansır

Kalite eşikleri: rtc_quality_thresholds uzaktan yapılandırma anahtarından okunur (rtt, kayıp, jitter, yeniden bağlanma, donma ağırlıkları).

Geçme ölçütü: Sinyal kaybı yok; çapraz seans sızıntısı yok.

Sıklık: Gerçek zamanlı/WebRTC değişikliklerinde.

9. Performance Test

Amaç: Gecikme ve kaynak kullanımının kabul sınırlarında kalması.

Ölçüm	Hedef
Okuma ucu p95	< 300 ms
Yazma ucu p95	< 600 ms
Hediye gönderimi p95	< 800 ms (transaction dahil)
SSE ilk bayt	< 500 ms
Veritabanı bağlantısı	Eşzamanlı 25 sınırına dayanmama
İfade zaman aşımı	5 saniyelik sınıra çarpan sorgu sıfır
Bellek	Uzun süreli SSE bağlantılarında sızıntı yok

Yük profilleri: CANLIFAL_LOAD_TEST_PLAN.md dokümanındaki senaryolar kullanılır (eşzamanlı izleyici, hediye fırtınası, oda doluluk).

Özel dikkat: İmleçli sayfalama eklenen 12 uçta, klasik `offset` moduna göre derin sayfa (page > 50) gecikmesi ölçülür; imleç modunun sabit zamanlı kaldığı doğrulanır.

Geçme ölçütü: Hedeflerin tamamı sağlanır; sapan uçlar indeks incelemesine alınır.

Sıklık: Sürüm öncesi.

10. Regression Test

Amaç: Geriye dönük uyumluluğun bozulmaması — projenin en katı kuralı.

Koruma	Yöntem
Yanıt şekli	502 yolun anlık görüntüsü saklanır; alan silinmesi/yeniden adlandırılması testi kırar
Alan ekleme	Yeni alan eklemek serbest (kırıcı değil), kaldırmak yasak
Sayfalama	?cursor= olmadan yapılan istek eski davranışı bit düzeyinde korumalı
Hata kodları	Mevcut kodun değeri değişemez; yalnızca yeni kod eklenir
SSE olay adları	Mevcut olay adı değişemez; yeni olay eklenebilir
Veritabanı	Yalnızca eklemeli değişiklik; sütun kaldırma/tip değiştirme onay gerektirir
Derleme kapısı	tsc --noEmit + üretim derlemesi her değişiklikte

Faz bazlı regresyon paketi: Faz 18-19'da imleç eklenen 12 uç ve Faz 20-23'te transaction'a alınan akışlar için kalıcı senaryo seti tutulur.

Geçme ölçütü: Tek bir kırıcı değişiklik bile birleştirmeyi engeller.

Sıklık: Her commit (derleme kapısı) + her sürüm (tam paket).

11. Özet Matris

#	Sınıf	Öncelik	Sıklık	Otomasyon durumu
1	Unit	Orta	Her commit	Yazılmadı
2	Integration	Yüksek	Her birleştirme	Yazılmadı
3	API sözleşme	Yüksek	Gecelik	Kısmen (OpenAPI mevcut)
4	Realtime	Yüksek	Gecelik	Elle betikler mevcut
5	Concurrency	Kritik	Haftalık	Elle doğrulandı (Faz 20/23)
6	Financial	Kritik	Gecelik	Yazılmadı
7	Security	Kritik	Sürüm öncesi	Kısmen (elle)
8	WebRTC	Orta	Değişiklikte	Elle
9	Performance	Orta	Sürüm öncesi	Plan mevcut
10	Regression	Kritik	Her commit	Derleme kapısı etkin

12. Uygulama Sırası Önerisi

1. **Financial** ve **Concurrency** — para kaybı riski en yüksek alanlar.
2. **Regression** anlık görüntü paketi — geriye dönük uyumluluğu makineye devret.
3. **API sözleşme** koşucusu — mevcut OpenAPI tanımından üretilebilir, en hızlı kazanç.
4. **Realtime** — mevcut elle betikler otomasyona çevrilir.
5. **Unit** — saf modüller çoğaldıkça değeri artar.
6. **Security, WebRTC, Performance** — sürüm kapısına bağlanır.